QUY TRÌNH KIỂM SOÁT VÀ CHUẨN HÓA KHÔNG GIAN LÀM VIỆC AN TOÀN

Vị trí: Chuyên gia Bảo mật Hệ thống

Đối tượng áp dụng: Nhân viên toàn công ty & Đội ngũ Phát triển Phần mềm

Phần 1 — Quy trình 3 bước kiểm tra an toàn khi nhận file từ Internet

Để ngăn chặn tuyệt đối các cuộc tấn công ngụy trang đuôi file kép (**Double Extension Attack**) và tệp tin chứa mã độc, mọi nhân viên khi tải file từ Email, Zalo, Slack hay trình duyệt phải thực hiện quy trình 3 bước sau trước khi mở tệp:

Cảnh báo an toàn
Tuyệt đối KHÔNG nhấp đôi chuột (double-click) để mở bất kỳ tệp tin nào từ Internet khi chưa hoàn thành bước kiểm tra hiển thị đuôi file thật.

1.Hiện đuôi tệp tin & File ẩn hệ thống: Kiểm tra cấu hình Windows File Explorer.

- **Mục đích:** Bắt buộc hệ điều hành hiển thị chính xác định dạng thực sự của tệp tin thay vì tên hiển thị ngụy trang.
- **Thao tác:** Trên thanh công cụ File Explorer → chọn **View** → chọn **Show** → Tích chọn 2 mục:
    1. **File name extensions** *(Hiển thị đuôi mở rộng file)*.
    2. **Hidden items** *(Hiển thị tệp/thư mục ẩn)*.
-
- **Xác minh bước:** Mọi tệp tin trên màn hình đều hiển thị phần mở rộng rõ ràng đằng sau dấu chấm cuối cùng (ví dụ: , ,).

2.Nhận diện cạm bẫy & Xử lý sự cố (Edge Case): Phân tích định dạng và phản ứng sự cố.

- **Quan sát tên file thực:** Sau khi bật hiển thị đuôi file, quan sát tên file vừa nhận:
    1. **Trường hợp an toàn:** Tên file kết thúc bằng hoặc thật.
    2. **Trường hợp mã độc ngụy trang (Edge Case):** Tên file lộ diện đuôi kép là (hoặc , ,).
-
- **Quy trình xử lý khẩn cấp khi phát hiện file giả mạo:**
    1. **KHÔNG khởi chạy/mở file** dưới mọi hình thức.
    2. Nhấn để xóa vĩnh viễn tệp tin khỏi máy tính (không đưa vào Recycle Bin).
    3. Báo cáo ngay lập tức cho bộ phận IT Security/SOC của công ty kèm theo thông tin địa chỉ email/tài khoản gửi file để tiến hành chặn IP/Domain trên Tường lửa (Firewall).
-

3.Rà soát tệp tin cấu hình ẩn nhạy cảm: Phòng chống thất thoát dữ liệu (.env / .git).

- **Kiểm tra tệp tin ẩn nguy hiểm:** Sau khi đã bật **Hidden items**, quét toàn bộ thư mục nhận tệp xem có chứa các file ẩn chứa thông tin nhạy cảm bị đính kèm ngầm hay không (ví dụ: , , ,).

- **Rủi ro của file :** File chứa toàn bộ chuỗi kết nối cơ sở dữ liệu (Database Connection String), Secret Key, API Tokens của hệ thống. Kẻ tấn công có thể lợi dụng để đánh cắp tài nguyên doanh nghiệp.
- **Xác minh bước:** Nếu phát hiện thư mục nhận về chứa file lạ hoặc có dấu hiệu bị đánh cắp, cô lập thư mục và thông báo cho đội dev thay đổi ngay lập tức toàn bộ Secret Keys/Passwords liên quan.

Phần 2 — Checklist "Developer Workspace Setup"

Bộ tiêu chuẩn cài đặt môi trường làm việc tối ưu cho Lập trình viên giúp cân bằng giữa **Hiệu suất làm việc (Performance)** và **An toàn thông tin (Security)**:

1. Cấu hình Hệ điều hành & File Explorer (Security First)

- [ ] **File name extensions:** Always **ON** (Hiển thị tất cả đuôi file).
- [ ] **Hidden items:** Always **ON** (Hiển thị các tệp tin ẩn ,).
- [ ] **Developer Mode (Windows 11):** Enable để tối ưu hóa hiệu năng câu lệnh CLI và Symlinks.
- [ ] **Execution Policy (PowerShell):** Cấu hình để cho phép chạy script phát triển an toàn.

2. Tổ chức Thư mục theo Mô hình 4 Trụ Cột & 3 Cấp (Ổ đĩa D:)

Thiết lập thư mục trên phân vùng dữ liệu để cách ly hoàn toàn với phân vùng hệ thống :

Plaintext

```
D:\ (Ổ đĩa Dữ liệu)
├── 01_Work/                    [Trụ cột 1: Công việc & Dự án]
│   └── cinebook-platform/      [Cấp 2: Tên dự án (kebab-case)]
│       ├── src/                [Cấp 3: Mã nguồn ứng dụng]
│       ├── assets/             [Cấp 3: Tài nguyên hình ảnh/media]
│       └── .env                [Tệp cấu hình ẩn]
├── 02_Learning/                [Trụ cột 2: Học tập & Nghiên cứu]
│   └── aws-cloud-practitioner/
│       └── docs/
├── 03_Personal/                [Trụ cột 3: Tài liệu cá nhân]
│   └── administrative-docs/
│       └── tax-2026/
└── 04_Media/                   [Trụ cột 4: Tài nguyên phim/ảnh giải trí]
    └── raw-footage/
        └── event-2026/
```

3. Quy tắc Đặt tên & Quản lý Mã nguồn (Naming & Path Rules)

- [ ] **Naming Convention:** Bắt buộc dùng cho thư mục và tài nguyên tĩnh (assets); hoặc cho file mã nguồn tùy theo ngôn ngữ.
- [ ] **No Spaces & Diacritics:** Không chứa khoảng trắng, không dùng tiếng Việt có dấu trong toàn bộ cấu trúc đường dẫn dự án.
- [ ] **Max Depth Limit:** Giới hạn tối đa **3 cấp thư mục** tính từ phân vùng gốc để tránh lỗi vượt quá độ dài đường dẫn ( ).

- [ ] **Relative Path Enforcement:** 100% tài nguyên liên kết trong mã nguồn bắt buộc phải sử dụng **Đường dẫn tương đối (Relative Path)** hoặc thư viện xử lý đường dẫn động (/).